

MINOR PROJECT — I

Cybersecurity Risk Assessment Framework for Small Businesses

Presented by: **Himanshu Soni**
Naviotech Solution Pvt Ltd · 2025–2026

CONFIDENTIAL

1. Introduction & Background

1.1 What is Cybersecurity?

Cybersecurity is the practice of protecting computers, networks, systems, and data from unauthorized access, cyber attacks, damage, or theft. It encompasses a wide range of technologies, processes, and practices designed to defend digital assets against increasingly sophisticated threats.

- Protects computers, networks, and digital devices from unauthorized access
- Secures internet connections and prevents hacking and cyber attacks
- Protects sensitive data, ensuring privacy, confidentiality, and integrity
- Maintains data availability and helps businesses stay safe online
- Reduces risks from malware, viruses, phishing, and ransomware

1.2 What are SMEs?

SMEs — Small and Medium Enterprises — are businesses that operate on a smaller scale than large corporations in terms of employees, revenue, and size. They are important contributors to the economy, generating employment and supporting innovation.

- Small and medium-sized businesses that contribute significantly to the economy
- Generate employment and require efficient resource management
- Often adopt digital technologies for growth, making cybersecurity critical
- Face unique risks from cyber attacks and data breaches due to limited IT budgets
- Examples: Local retail stores, small manufacturing units, startups, consulting firms

2. Objectives of the Study

1. Identify Cybersecurity Risks in SMEs

Analyse the most prevalent and damaging cyber threats faced by small businesses — including phishing, ransomware, insider threats, weak passwords, and unpatched software.

2. Develop a Risk Assessment Framework

Build a structured, quantitative model ($\text{Risk Score} = \text{Likelihood} \times \text{Impact}$) that SMEs can use to prioritise threats based on severity and probability.

3. Propose Mitigation Strategies

Recommend practical, cost-effective security controls such as MFA, RBAC, employee training, data backups, and patch management aligned with the NIST Cybersecurity Framework.

4. Validate Through Real-World Case Studies

Test the framework against three SME scenarios (retail, healthcare, IT services) to demonstrate its effectiveness in identifying high-priority risks and guiding remediation.

3. Cybersecurity Risks in SMEs

3.1 Top 5 Cybersecurity Threats

01 — Phishing Attacks

Fake emails, messages, or websites used to steal sensitive information and login credentials. The most common entry point for cyber attacks on SMEs.

02 — Ransomware

Malicious software that encrypts files and demands payment for restoring access. Can cause complete operational shutdown and significant financial loss.

03 — Insider Threats

Employees or partners may intentionally or accidentally expose sensitive data. Often underestimated but can cause major data breaches.

04 — Weak Passwords

Poor password practices make it easier for attackers to gain unauthorized access. Mitigated effectively through MFA and password policies.

05 — Unpatched Software

Outdated software contains vulnerabilities that cybercriminals can exploit. Regular patch management is critical to reduce attack surface.

3.2 Impact of Cyber Attacks on SMEs

- **Financial Losses:** Direct monetary loss from fraud, ransom payments, and recovery costs.
- **Data Theft:** Sensitive business and customer data stolen or sold on dark web.
- **Business Disruption:** Operations halted, leading to lost productivity and revenue.
- **Reputation Damage:** Brand credibility harmed; long-term customer relationships at risk.
- **Loss of Customer Trust:** Customers lose confidence and switch to competitors.

4. Risk Assessment Framework

4.1 Risk Assessment Model

The framework uses a quantitative scoring model: **Risk Score = Likelihood × Impact**. Both Likelihood and Impact are rated on a scale of 1 to 5, producing a Risk Score ranging from 1 to 25. This allows SMEs to systematically prioritize threats.

Risk / Threat	Likelihood (1–5)	Impact (1–5)	Risk Score	Risk Level
Phishing Attacks	5	4	20	High
Ransomware	4	5	20	High
Insider Threats	3	5	15	High
Weak Passwords	5	4	20	High
Unpatched Software	4	4	16	High

4.2 Risk Level Scale

Score Range	Risk Level	Priority
1 – 5	Low	Monitor
6 – 10	Medium	Plan
11 – 15	High	Respond Soon
16 – 25	Critical	Immediate Action

5. NIST Cybersecurity Framework

The NIST Cybersecurity Framework (CSF) v2.0 provides five core functions applied to SME cybersecurity risk management:

IDENTIFY

- Asset Management
- Business Environment
- Governance
- Risk Assessment
- Supply Chain Risk Management

PROTECT

- Access Control
- Awareness & Training
- Data Security
- Maintenance
- Protective Technology

DETECT

- Anomalies & Events
- Continuous Monitoring
- Detection Processes

RESPOND

- Response Planning
- Communications
- Analysis
- Mitigation

RECOVER

- Recovery Planning
- Improvements
- Communications

6. Mitigation Strategies

6.1 Security Controls by Threat

Threat	Mitigation Controls	Risk Reduction
Phishing Attacks	Email filters, Security awareness training, MFA	High
Ransomware	Regular backups, Endpoint security, Patch management	High
Insider Threats	RBAC, Access monitoring, Least privilege policy	Medium–High
Weak Passwords	MFA, Password managers, Strong password policy	High
Unpatched Software	Automated patch management, Vulnerability scanning	High

6.2 Best Practices for SME Cybersecurity

- ✓ Implement Multi-Factor Authentication (MFA) for all critical accounts
- ✓ Use strong password policies and password managers
- ✓ Install and maintain firewalls and antivirus software
- ✓ Perform regular software updates and patch management
- ✓ Conduct employee cybersecurity awareness training
- ✓ Create regular data backups and test recovery procedures
- ✓ Apply Role-Based Access Control (RBAC) and least privilege
- ✓ Encrypt sensitive business and customer data
- ✓ Monitor systems for suspicious activities and incidents
- ✓ Perform periodic security audits and risk assessments

7. Case Studies & Validation

Case Study: Retail Store

Threat	Phishing Attack
Severity	High
Scenario	Phishing email caused credential theft compromising POS system.
Controls Applied	MFA + Employee Training
Outcome	Reduced credential theft; staff can now identify phishing emails.

Case Study: Healthcare Clinic

Threat	Ransomware
Severity	Critical
Scenario	Ransomware encrypted patient records, halting clinical operations.
Controls Applied	Backups + Endpoint Security
Outcome	Fast recovery from attack with minimal data loss.

Case Study: IT Services Firm

Threat	Insider Threat
Severity	High
Scenario	Disgruntled employee exfiltrated sensitive client data before resignation.
Controls Applied	RBAC + Access Audits
Outcome	Prevented future data exposure; audit trails identified the breach source.

8. Key Findings

1. SMEs face significant cybersecurity risks due to limited security resources.
2. Phishing attacks and ransomware are the most critical external threats.
3. Insider threats can cause major data breaches and operational disruptions.
4. Weak passwords and unpatched software increase vulnerability to cyberattacks.
5. Risk assessment helps SMEs prioritize threats based on likelihood and impact.
6. Security controls such as MFA, firewalls, backups, and employee training effectively reduce cyber risks.

9. Conclusion

A proactive cybersecurity approach combining risk assessment, employee awareness, and technical controls can significantly reduce cyber threats for SMEs. The risk assessment model effectively identified the most severe threats. Mitigation strategies reduced both the likelihood and impact of attacks. The model is applicable across retail, healthcare, and IT services sectors. Prioritizing risks by severity helps SMEs allocate cybersecurity resources effectively.

By implementing these best practices, SMEs can improve data protection, business continuity, and customer trust while minimising financial and operational risks.

10. Limitations & Future Scope

10.1 Limitations

- Study limited to 3 SME case studies; broader validation across industries is needed.
- The risk model uses a simplified Likelihood × Impact formula — advanced weighted scoring could improve precision.
- Framework has not been tested on large enterprises or multinational organisations.
- Threat landscape evolves rapidly; model requires periodic updates to remain current.

10.2 Future Scope

- Integrate AI & machine learning for real-time automated threat detection and risk scoring.
- Develop an automated risk scoring tool / dashboard SMEs can self-administer with minimal expertise.
- Expand the framework to cover cloud security, IoT devices, and remote-work environments.
- Align with additional standards: ISO/IEC 27001, GDPR compliance, and OWASP Top 10.

11. References & Bibliography

[1] NIST Cybersecurity Framework (CSF) v2.0

National Institute of Standards and Technology. (2024). Cybersecurity Framework.
<https://www.nist.gov/cyberframework>

[2] ISO/IEC 27001:2022 — Information Security Management

International Organization for Standardization. Information security, cybersecurity and privacy protection.

[3] OWASP Top 10 — Web Application Security Risks

Open Web Application Security Project. (2021). OWASP Top 10. <https://owasp.org/www-project-top-ten/>

[4] Cybersecurity for Small Businesses — FCC Guide

Federal Communications Commission. Cybersecurity Planning Guide. <https://www.fcc.gov/cyberplanner>

[5] Verizon Data Breach Investigations Report (DBIR)

Verizon. (2023). Data Breach Investigations Report — SMB threat landscape analysis.

[6] Risk Assessment Methodology — ENISA

European Union Agency for Cybersecurity. (2023). ENISA Threat Landscape for SMEs.